

OLIVE SERVICE • SYSTÈME INTÉGRÉ DE GESTION COMMERCIALE & FINANCIÈRE

RÉFÉRENTIEL RBAC COMPLET

Contrôle d'Accès Basé sur les Rôles, Cartographie Sécuritaire & Découpage Granulaire

Protection des Contrôleurs, Routes, Vues, Liens de Navigation et Boutons d'Action

Statut du Document :	RÉFORME SÉCURITAIRE APPLIQUÉE (v2.0)
Date de Référence :	06 September 2026
Rôles Modélisés :	4 Métiers Opérationnels + 1 Super Administrateur
Permissions Actives :	34 Permissions Granulaires Enregistrées
Niveau de Sécurité :	DOUBLE CONTRÔLE (Serveur 403 + Client UI)

Ce document constitue le registre exhaustif de gouvernance des habilitations pour l'ensemble des modules :
Commercial • Finance & Comptabilité • Gestion du Catalogue • Administration Globale

1. Synthèse de la Réforme de Sécurité & Architecture RBAC

Antérieurement à cette réforme, l'application reposait principalement sur une vérification binaire d'authentification (`$this->requireAuth()`). Tout utilisateur connecté possédait potentiellement la capacité d'invoquer des actions sensibles (validation de versements, modification d'articles ou de dépenses, suppression d'utilisateurs) dès lors qu'il connaissait ou forgeait les requêtes HTTP correspondantes.

La mise à niveau sécuritaire introduit un modèle **RBAC (Role-Based Access Control)** rigoureux et étanche à deux niveaux :

1. Verrouillage Serveur Strict (Backend) : Chaque contrôleur et chaque méthode vérifie désormais explicitement les autorisations requises via `$this->requirePermission(...)` ou `$this->requireRole(...)`. Si l'utilisateur ne possède pas le droit requis, la requête est immédiatement avortée avec un code **HTTP 403 Forbidden**. En cas d'appel AJAX, un payload JSON normalisé `{"status": 0, "message": "Accès refusé..."}` est retourné.

2. Dégradation et Masquage Dynamique de l'Interface (Frontend) : Les éléments d'interface sont synchronisés avec les droits de la session :

- Les menus et rubriques de la barre latérale (`sidebar.php`) et de la barre de navigation (`nav.php`) ne s'affichent que si l'utilisateur possède le rôle ou la permission adéquate via `Context::can()`.
- Les boutons d'action majeurs (ex. "Saisir un versement", "Nouvelle dépense", "Nouvel article", "Nouvel utilisateur") sont conditionnés en PHP.
- Les boutons de tableau DataTables (Éditer, Activer/Désactiver le statut) sont restreints via `window.AppConfig.can(...)` injecté dynamiquement dans `header.php`.

2. Référentiel des Rôles et Périmètres Métier

La plateforme structure l'organisation du travail autour de 4 rôles opérationnels majeurs, supervisés par le Super Administrateur :

Code Rôle	Dénomination	Périmètre & Responsabilité Opérationnelle
ROLE_COMMERCIAL	Commercial Terrain	Prospection, enrôlement des clients, création de souscriptions, encaissement des cotisations terrain, ouverture/clôture de sa propre caisse journalière, et initiation des versements vers la finance.
ROLE_FINANCE	Responsable Finance & Compta	Contrôle financier, validation ou rejet des versements initiés par les commerciaux, supervision des clôtures de caisse, engagement et saisie des dépenses et gestion des types de dépenses.
ROLE_GESTIONNAIRE	Gestionnaire Catalogue & Logistique	Définition du catalogue des articles, composition des packs promotionnels, planification des sessions annuelles, suivi et remise logistique des packs (distributions aux souscripteurs soldés).
ROLE_ADMIN	Administrateur Système	Administration technique, création et gestion des comptes utilisateurs, attribution des rôles et des permissions, configuration des zones géographiques et des paramètres de l'établissement.
ROLE_SUPERADMIN	Super Administrateur	Droits suprêmes d'audit, dérogation technique, accès illimité à tous les modules, contournement des verrous d'activation de jetons et maintenance globale.

3. Registre Exhaustif des 34 Permissions Granulaires par Module

La base de données recense exactement 34 permissions réparties dans 5 modules fonctionnels. Le tableau ci-dessous dresse l'inventaire complet de ces privilèges unitaires :

N°	Code Permission	Module	Libellé / Finalité Métier
1	ADMIN_MANAGE_ETABLISSEMENTS	ADMINISTRATION	Configurer la structure des établissements
2	ADMIN_MANAGE_PERMISSIONS	ADMINISTRATION	Gestion des permissions granulaires
3	ADMIN_MANAGE_ROLES	ADMINISTRATION	Gestion et attribution des rôles RBAC
4	ADMIN_MANAGE_USERS	ADMINISTRATION	Gestion des comptes utilisateurs système
5	ADMIN_MANAGE_ZONES	ADMINISTRATION	Gérer les zones géographiques
6	ADMIN_VIEW_RAPPORTS_FINANCIERS	ADMINISTRATION	Tirer les rapports financiers globaux
7	ADMIN_VIEW_STATISTIQUES	ADMINISTRATION	Consulter les statistiques et tableaux de bord généraux
8	GESTIONNAIRE_MANAGE_ANNEES	CATALOGUE	Gérer les années d'activité
9	GESTIONNAIRE_MANAGE_ARTICLES	CATALOGUE	CRUD sur le catalogue d'articles
10	GESTIONNAIRE_MANAGE_CATEGORIE_PACKS	CATALOGUE	Gérer les catégories de packs
11	GESTIONNAIRE_MANAGE_CATEGORIES_ARTICLES	CATALOGUE	Gérer les catégories d'articles
12	GESTIONNAIRE_MANAGE_PACKS	CATALOGUE	Créer & Configurer les Packs d'articles
13	GESTIONNAIRE_MANAGE_SESSIONS	CATALOGUE	Gérer les sessions de souscription
14	COMMERCIAL_ADD_CLIENT	COMMERCIAL	Enregistrer un nouveau client
15	COMMERCIAL_ADD_SOUSCRIPTION	COMMERCIAL	Enregistrer une souscription client
16	COMMERCIAL_COLLECT_COTISATION	COMMERCIAL	Collecter des cotisations terrain (statut en attente)
17	COMMERCIAL_MAKE_VERSEMENT	COMMERCIAL	Effectuer un versement de caisse
18	COMMERCIAL_MANAGE_OWN_CAISSE	COMMERCIAL	Ouvrir et clôturer sa caisse journalière
19	COMMERCIAL_VIEW_OWN_CLIENTS	COMMERCIAL	Consulter la liste de ses clients
20	COMMERCIAL_VIEW_OWN_COTISATIONS	COMMERCIAL	Consulter l'historique de ses cotisations
21	COMMERCIAL_VIEW_OWN_SOUSCRIPTIONS	COMMERCIAL	Consulter ses propres souscriptions
22	FINANCE_EDIT_COTISATION	FINANCE	Modifier une cotisation client
23	FINANCE_MANAGE_CLOTURES_CAISSE	FINANCE	Valider la clôture générale des caisses
24	FINANCE_MANAGE_DEPENSES	FINANCE	Saisir et ordonnancer les dépenses d'exploitation
25	FINANCE_MANAGE_TYPE_DEPENSES	FINANCE	Gérer les catégories de dépenses
26	FINANCE_REJECT_VERSEMENT	FINANCE	Rejeter les versements non conformes
27	FINANCE_VALIDATE_VERSEMENT	FINANCE	Valider les versements des commerciaux
28	FINANCE_VIEW_ALL_COTISATIONS	FINANCE	Consulter toutes les cotisations clients
29	FINANCE_VIEW_CLOTURES_CAISSE	FINANCE	Consulter le journal global des caisses
30	GESTIONNAIRE_EDIT_CLIENT	GESTIONNAIRE	Modifier les informations des clients
31	GESTIONNAIRE_EDIT_SOUSCRIPTION	GESTIONNAIRE	Modifier les souscriptions clients
32	GESTIONNAIRE_MANAGE_DISTRIBUTIONS	GESTIONNAIRE	Gérer et valider la distribution des packs
33	GESTIONNAIRE_VIEW_ALL_CLIENTS	GESTIONNAIRE	Consulter l'ensemble du fichier client
34	GESTIONNAIRE_VIEW_ALL_SOUSCRIPTIONS	GESTIONNAIRE	Consulter l'ensemble des souscriptions

4. Matrice Croisée Rôles × Permissions (Habilitations)

Le tableau croisé ci-après détaille l'affectation exacte de chacune des 34 permissions aux 4 rôles opérationnels (ROLE_COMMERCIAL, ROLE_FINANCE, ROLE_GESTIONNAIRE, ROLE_ADMIN) ainsi qu'au ROLE_SUPERADMIN.

Permission	Commercial	Finance	Gestionnaire	Admin	SuperAdmin
ADMIN_MANAGE_ETABLISSEMENTS	—	—	—	✓	✓
ADMIN_MANAGE_PERMISSIONS	—	—	—	✓	✓
ADMIN_MANAGE_ROLES	—	—	—	✓	✓
ADMIN_MANAGE_USERS	—	—	—	✓	✓
ADMIN_MANAGE_ZONES	—	—	—	✓	✓
ADMIN_VIEW_RAPPORTS_FINANCIERS	—	—	—	✓	✓
ADMIN_VIEW_STATISTIQUES	—	—	—	✓	✓
GESTIONNAIRE_MANAGE_ANNEES	—	—	✓	✓	✓
GESTIONNAIRE_MANAGE_ARTICLES	—	—	✓	✓	✓
GESTIONNAIRE_MANAGE_CATEGORIE_PACKS	—	—	✓	✓	✓
GESTIONNAIRE_MANAGE_CATEGORIES_ARTICLES	—	—	✓	✓	✓
GESTIONNAIRE_MANAGE_PACKS	—	—	✓	✓	✓
GESTIONNAIRE_MANAGE_SESSIONS	—	—	✓	✓	✓
COMMERCIAL_ADD_CLIENT	✓	—	—	✓	✓
COMMERCIAL_ADD_SOUSCRIPTION	✓	—	—	✓	✓
COMMERCIAL_COLLECT_COTISATION	✓	—	—	✓	✓
COMMERCIAL_MAKE_VERSEMENT	✓	—	—	✓	✓
COMMERCIAL_MANAGE_OW_N_CAISS	✓	—	—	✓	✓
COMMERCIAL_VIEW_OW_N_CLIENTS	✓	—	—	✓	✓
COMMERCIAL_VIEW_OW_N_COTISATIONS	✓	—	—	✓	✓
COMMERCIAL_VIEW_OW_N_SOUSCRIPTIONS	✓	—	—	✓	✓
FINANCE_EDIT_COTISATION	—	✓	—	✓	✓
FINANCE_MANAGE_CLOTURES_CAISS	—	✓	—	✓	✓
FINANCE_MANAGE_DEPENSES	—	✓	—	✓	✓
FINANCE_MANAGE_TYPE_DEPENSES	—	✓	—	✓	✓
FINANCE_REJECT_VERSEMENT	—	✓	—	✓	✓
FINANCE_VALIDATE_VERSEMENT	—	✓	—	✓	✓
FINANCE_VIEW_ALL_COTISATIONS	—	✓	—	✓	✓
FINANCE_VIEW_CLOTURES_CAISS	—	✓	—	✓	✓
GESTIONNAIRE_EDIT_CLIENT	—	—	✓	✓	✓
GESTIONNAIRE_EDIT_SOUSCRIPTION	—	—	✓	✓	✓
GESTIONNAIRE_MANAGE_DISTRIBUTIONS	—	—	✓	✓	✓
GESTIONNAIRE_VIEW_ALL_CLIENTS	—	—	✓	✓	✓

Permission	Commercial	Finance	Gestionnaire	Admin	SuperAdmin
GESTIONNAIRE_VIEW_ALL_SOUSCRIPTIONS	—	—	✓	✓	✓

5. Sécurisation Granulaire par Module : Contrôleurs, Routes, Vues, Liens et Boutons

Cette section recense pour chaque ressource du système : l'URL, le contrôleur concerné, les permissions requises, l'emplacement exact des liens et boutons dans l'interface, et le comportement automatique en cas d'accès non autorisé.

5.1 Module Commercial & Ventes

Route / Action	Permission Requise	Rôles Habilités	Emplacement Vues / Liens / Boutons	Comportement si non autorisé
/client/list /client/apiList	COMMERCIAL_VIEW_OWN_CLIENTS ou GESTIONNAIRE_VIEW_ALL_CLIENTS	Commercial, Gestionnaire, Admin, SuperAdmin	Lien Sidebar "Clients" Vue views/clients/list.php	Lien masqué dans sidebar. Requête directe → HTTP 403.
/client/formulaire /client/add	COMMERCIAL_ADD_CLIENT	Commercial, Admin, SuperAdmin	Bouton "+ Nouveau Client" dans views/clients/list.php	Bouton non affiché. POST direct → JSON 403.
/client/edition/{id} /client/edit	GESTIONNAIRE_EDIT_CLIENT	Gestionnaire, Admin, SuperAdmin	Bouton "Éditer" dans colonne actions DataTable (clients.js)	Bouton retiré du DOM par DataTables. Accès URL → HTTP 403.
/souscription/list	COMMERCIAL_VIEW_OWN_SOUSCRIPTIONS ou GESTIONNAIRE_VIEW_ALL_SOUSCRIPTIONS	Commercial, Gestionnaire, Admin, SuperAdmin	Lien Sidebar "Souscriptions" Vue views/souscriptions/list.php	Lien sidebar masqué. Accès direct → HTTP 403.
/souscription/createWizard /souscription/wizardSubmit	COMMERCIAL_ADD_SOUSCRIPTION	Commercial, Admin, SuperAdmin	Bouton "+ Nouvelle souscription" dans views/souscriptions/list.php	Bouton non généré. POST direct → JSON 403.
/cautisation/searchForm /cautisation/store	COMMERCIAL_COLLECT_COTISATION	Commercial, Admin, SuperAdmin	Lien Sidebar "Paielement Cotisation" Vue views/cautisations_payment/search.php	Lien masqué. Soumission formulaire → JSON 403.
/caisse_commercial/list	COMMERCIAL_MANAGE_OWN_CAISSE ou FINANCE_VIEW_CLOTURES_CAISSE	Commercial, Finance, Admin, SuperAdmin	Lien Sidebar "Ma Caisse Journalière" Vue views/caisse_commercial/list.php	Lien masqué. Accès direct → HTTP 403.
/versement/formulaire /versement/add	COMMERCIAL_MAKE_VERSEMENT	Commercial, Admin, SuperAdmin	Bouton "Saisir un Versement" dans views/versements/list.php	Bouton invisible (Context::can). POST → JSON 403.

5.2 Module Finance & Gestion des Fonds

Route / Action	Permission Requête	Rôles Habilités	Emplacement Vues / Liens / Boutons	Comportement si non autorisé
/versement/valider /versement/changer	FINANCE_VALIDATE_VERSEMENT	Finance, Admin, SuperAdmin	Boutons "Valider" et "Rejeter" dans views/versements/details.php	Boutons masqués (interdits aux commerciaux). POST → JSON 403.
/caisse_commercial/changer /caisse_commercial/edit	FINANCE_MANAGE_CLOTURES_CAISSE	Finance, Admin, SuperAdmin	Bouton de validation de clôture de caisse commerciale	Action bloquée côté serveur. Réponse JSON 403.
/depense/list /depense/apiList	FINANCE_MANAGE_DEPENSES	Finance, Admin, SuperAdmin	Lien Sidebar "Dépenses & Frais" Vue views/depenses/list.php	Lien sidebar masqué. Accès direct → HTTP 403.
/depense/formulaire /depense/add	FINANCE_MANAGE_DEPENSES	Finance, Admin, SuperAdmin	Bouton "Nouvelle Dépense" dans views/depenses/list.php	Bouton non rendu. POST direct → JSON 403.
/type_depense/*	FINANCE_MANAGE_TYPE_DEPENSES	Finance, Admin, SuperAdmin	Lien Sidebar "Types de Dépenses" Bouton "+ Nouveau Type Dépense" Toggle statut & boutons Éditer	Lien masqué. Boutons masqués & toggles inactifs. Accès direct → HTTP 403.

5.3 Module Catalogue, Sessions & Logistique

Route / Action	Permission Requête	Rôles Habilités	Emplacement Vues / Liens / Boutons	Comportement si non autorisé
/article/*	GESTIONNAIRE_MANAGE_ARTICLES	Gestionnaire, Admin, SuperAdmin	Lien Sidebar "Articles & Produits" Bouton "+ Nouvel Article" Toggle statut & bouton Éditer DataTables	Lien sidebar masqué. Boutons omis. Interdit aux commerciaux & finance.
/pack/*	GESTIONNAIRE_MANAGE_PACKS	Gestionnaire, Admin, SuperAdmin	Lien Sidebar "Packs Promotionnels" Bouton "+ Nouveau Pack" Toggle statut & bouton Éditer (packs.js)	Lien masqué. Bouton masqué. Accès direct → HTTP 403.
/session/*	GESTIONNAIRE_MANAGE_SESSIONS	Gestionnaire, Admin, SuperAdmin	Lien Sidebar "Sessions d'Activité" Bouton "+ Nouvelle Session" Toggle statut & bouton Éditer	Lien masqué. Accès direct → HTTP 403.
/distribution/*	GESTIONNAIRE_MANAGE_DISTRIBUTIONS	Gestionnaire, Admin, SuperAdmin	Lien Sidebar "Distributions & Remises" Bouton "+ Valider une Distribution" Bouton Éditer	Lien masqué. Bouton d'ajout conditionné. Accès non autorisé → HTTP 403.
/annee/*	GESTIONNAIRE_MANAGE_ANNÉES	Gestionnaire, Admin, SuperAdmin	Lien Sidebar "Années Académiques" Bouton "+ Nouvelle Année" Toggle statut & bouton Éditer	Lien masqué. Accès direct → HTTP 403.

5.4 Module Administration Système & Sécurité

Route / Action	Permission Requise	Rôles Habilités	Emplacement Vues / Liens / Boutons	Comportement si non autorisé
/user/list /user/formulaire /user/changer	ADMIN_MANAGE_USERS	Admin, SuperAdmin	Lien Sidebar "Utilisateurs & Personnel" Bouton "+ Nouvel Utilisateur" Toggle statut & bouton Éditer	Rubrique entière masquée. Toute tentative GET/POST → HTTP/JSON 403.
/role/*	ADMIN_MANAGE_ROLES	Admin, SuperAdmin	Lien Sidebar "Rôles & Profils" Bouton "+ Nouveau Rôle" Toggle statut & bouton Éditer	Lien masqué. Accès direct → HTTP 403.
/permission/*	ADMIN_MANAGE_PERMISSIONS	Admin, SuperAdmin	Lien Sidebar "Permissions Granulaires" Bouton "+ Ajouter Permission" Toggle statut & bouton Éditer	Lien masqué. Accès direct → HTTP 403.
/zone/*	ADMIN_MANAGE_ZONES	Admin, SuperAdmin	Lien Sidebar "Zones Commerciales" Bouton "+ Nouvelle Zone" Toggle statut & bouton Éditer	Lien masqué. Accès direct → HTTP 403.
/etablissement/*	ADMIN_MANAGE_ETABLISSEMENTS	Admin, SuperAdmin	Lien Sidebar "Configuration Établissement" Formulaire de mise à jour identité visuelle	Lien masqué. Soumission → HTTP 403.
/fonction/*	ADMIN_MANAGE_USERS	Admin, SuperAdmin	Lien Sidebar "Fonctions & Postes RH" Bouton "+ Ajouter Fonction" Toggle statut & bouton Éditer	Lien masqué. Accès direct → HTTP 403.

6. Mécanisme de Filtrage Multi-Tenant & Cloisonnement des Données

En complément des permissions RBAC sur les écrans et les contrôleurs, un cloisonnement strict des données en base garantit la confidentialité entre zones géographiques, établissements et agents :

etablissement_code	Isolation stricte de la structure juridique et financière. Aucune requête ne peut croiser les données de deux établissements distincts.
zone_code	Découpage territorial opérationnel. Les commerciaux et gestionnaires n'accèdent qu'aux enregistrements (clients, souscriptions, cotisations, caisses, versements, distributions) associés à leur zone d'affectation.
annee_code	Cloisonnement de l'exercice comptable et de la campagne annuelle en cours.
user_code (Agent)	Pour les utilisateurs ayant le rôle <code>ROLE_COMMERCIAL</code> , les requêtes sur les clients, souscriptions, cotisations et caisses filtrent systématiquement par leur propre identifiant d'agent, interdisant la consultation des dossiers gérés par leurs collègues.

7. Politiques de Réponse et Comportement en cas d'Accès Non Autorisé

Réponse aux requêtes Web Standards (Navigation par navigateur) :

Lorsqu'un utilisateur tente d'accéder par URL directe à une page dont il ne possède pas les droits, le système déclenche `BaseController::requirePermission()`. Celui-ci affiche immédiatement la vue d'erreur dédiée `views/errors/403.php` avec un statut **HTTP 403 Forbidden**, un message explicite stipulant la permission manquante, et un bouton de retour sécurisé vers le tableau de bord autorisé.

Réponse aux requêtes Asynchrones (AJAX / Fetch / DataTables) :

Pour toute requête effectuée avec l'en-tête `X-Requested-With: XMLHttpRequest` ou sollicitant une API, le contrôleur émet un en-tête **HTTP/1.1 403 Forbidden** ainsi qu'un corps JSON standardisé :

```
{ "status": 0, "success": false, "message": "Accès refusé : vous n'avez pas l'autorisation nécessaire (CODE_PERMISSION)." }
```


Le client JavaScript (Toastr / Alert) intercepte cette réponse et informe l'utilisateur sans interruption du fonctionnement général de la page.

8. Bonnes Pratiques d'Administration & Procédure d'Attribution

Pour préserver l'intégrité du système de contrôle d'accès, l'équipe de direction et les administrateurs doivent observer les règles de gouvernance suivantes :

1. **Principe du Moindre Privilège** : Chaque collaborateur ne doit recevoir que le rôle strictement nécessaire à l'exercice quotidien de ses fonctions. Il est formellement déconseillé d'attribuer `ROLE_ADMIN` à un agent opérationnel.
2. **Séparation des Pouvoirs (Versement vs Validation)** : Le commercial qui initie la collecte et le versement (`ROLE_COMMERCIAL`) ne doit en aucun cas disposer de la permission de validation financière (`FINANCE_VALIDATE_VERSEMENT`). Cette séparation est scellée dans la matrice RBAC.
3. **Activation des Comptes par Jeton** : La création d'un utilisateur génère un jeton envoyé par email. Seul le `ROLE_SUPERADMIN` est autorisé à activer manuellement un compte dont le jeton n'a pas encore été validé par l'intéressé.
4. **Audit Régulier des Rôles** : Il est recommandé d'exporter et de réexaminer périodiquement ce registre pour s'assurer qu'aucune dérive d'habilitation n'a été introduite dans la table `role_permissions`.

Visa Direction Technique & Sécurité
Système de Contrôle d'Accès Olive Service ERP
✓ SÉCURITÉ CERTIFIÉE v2.0

Visa Direction Générale
Validation de la Matrice d'Habilitations
Document Exécutoire Officiel